

PHASED ROADMAP

PesaGuard

Complete Build Roadmap — Consolidated from All Build Prompts

Consolidates	Master Build Prompt, Gaps Addendum, Tenant/Threat/Billing Addendum, Data Residency/Localization/Scope Addendum
Total phases	15 build phases + 1 parallel business track
Prepared for	Victor Kipruto Rop · DataForge
Date	July 2026

This roadmap sequences every requirement from the underlying prompts into one ordered build plan. It is a summary for planning and tracking — the full requirement tables, file lists, and constraints live in the individual prompt documents.

OVERVIEW

Phase Summary

All 15 phases, in build order, with source prompt and approximate timeline. Timelines assume solo/small-team development and should be treated as planning estimates, not commitments.

Phase	Focus	Timeline	Source Prompt
0	Discovery & Validation	Week 1	Master Build Prompt
1	Core Pipeline	Weeks 2-3	Master Build Prompt
2	Real Matching & Reconciliation Logic	Weeks 4-5	Master Build Prompt
3	Alerting System	Weeks 6-7	Master Build Prompt
4	Monitoring & Observability	Weeks 8-9	Master Build Prompt
5	Dashboards (Operational + Customer)	Weeks 10-12	Master Build Prompt
6	Security & API Protection	Week 13	Master Build Prompt
7	Backup, DR & Data Retention	Week 14	Master Build Prompt
8	Incident Response Tooling	Week 15	Master Build Prompt
9	API Documentation	Week 15 (parallel)	Master Build Prompt
10	Testing & Hardening	Weeks 16-17	Master Build Prompt
11	Deployment & Launch	Week 18+	Master Build Prompt
12	Operational Gaps (OAuth, Staging, Scanning, RBAC, Export, Versioning, Rotation)	Weeks 19-20	Gaps Addendum
13	Tenant Lifecycle, Threat Model, Feature Flags, Billing, Help Docs	Weeks 21-23	Tenant/Threat/Billing Addendum
14	Data Residency, Localization & Payment Scope	Weeks 24-25	Addendum III

A parallel Business & Operational Readiness track (ToS, DPA, ODPC registration, pricing, insurance) runs alongside phases 5 onward — see the appendix.

Phase-by-Phase Detail

PHASE 0

Week 1 · No code

Discovery & Validation

Master Build Prompt

- Identify 5-10 candidate pilot customers (SACCOs, e-commerce operators)
- Validate manual reconciliation pain is real and access to internal systems is grantable
- Confirm Daraja sandbox access and pull real callback payload samples
- **Gate:** do not proceed without directional validation of a real pilot customer

PHASE 1

Weeks 2-3

Core Pipeline

Master Build Prompt

- Webhook receiver validating and ingesting Daraja callbacks
- Kafka publish to mpesa.transactions.raw
- Tenant-scoped Postgres schema from day one (transactions, discrepancies, audit log)
- Persistent duplicate/invalid/large-amount detection
- Full audit logging; docker-compose for local dev

PHASE 2

Weeks 4-5

Real Matching & Reconciliation Logic

Master Build Prompt

- PostgresConnector with per-tenant field mapping
- Phone + amount + time-window matching against internal records
- needs_review tier for partial matches (not a hard discrepancy)
- Missing-callback detection and auto-resolution of late matches
- ConnectorRegistry so reconciliation logic stays tenant-agnostic

PHASE 3

Weeks 6-7

Alerting System

Master Build Prompt

- Dedicated alerting service consuming mpesa.discrepancies
- Multi-channel: Slack, SMS (Africa's Talking), email
- Severity tiers (info/warning/critical) with distinct routing
- Escalation, acknowledgement, daily digest, per-tenant config
- Alert deduplication and full delivery audit logging

PHASE 4

Weeks 8-9

Monitoring & Observability

Master Build Prompt

- /health and Prometheus-compatible /metrics on every service
- Structured JSON logs correlated by tenant_id/trans_id
- Kafka lag, latency, discrepancy rate, connector health tracked
- Operator alerting routed to a separate ops-only channel — never the customer channel
- RUNBOOK.md for common failure scenarios

PHASE 5

Weeks 10-12

Dashboards

Master Build Prompt

- Operational Grafana dashboard, provisioned as code, for internal use
- Customer-facing Next.js dashboard: discrepancy feed, detail view, resolution flow, reconciliation chart, tenant settings
- Simple auth; every view/API call tenant-scoped
- **Business track begins in parallel from this phase onward** (see appendix)

PHASE 6

Week 13

Security & API Protection

Master Build Prompt

- Rate limiting and request size limits on webhook receiver and dashboard API
- Daraja source validation (IP allowlist or shared secret)
- Expiring/revocable dashboard auth tokens
- Tenant isolation enforced at the database query layer

PHASE 7

Week 14

Backup, DR & Data Retention

Master Build Prompt

- Automated, off-instance Postgres backups with a tested restore procedure
- Deliberate Kafka topic retention for post-incident replay
- Documented retention periods and tenant offboarding (export + delete)
- Audit log retention handled as its own rule

PHASE 8

Week 15

Incident Response Tooling

Master Build Prompt

- Concrete on-call/paging definition for operator alerts
- SEV1/SEV2/SEV3 severity definitions
- Customer notification template and postmortem template
- Single INCIDENT_RESPONSE.md tying it together

PHASE 9

Week 15 · parallel with
Phase 8

API Documentation

Master Build Prompt

- OpenAPI/Swagger spec for the dashboard API
- Interactive docs endpoint (Swagger UI or equivalent)

PHASE 10

Weeks 16-17

Testing & Hardening

Master Build Prompt

- Unit tests for every anomaly rule and matching scenario
- Integration test against realistic Daraja sandbox fixtures
- Idempotency, load, and multi-tenant isolation tests
- Escalation-timing test; verify operator/customer alert channels never cross

PHASE 11

Week 18+

Deployment & Launch

Master Build Prompt

- Single-VM docker-compose production deployment (default)
- GitHub Actions CI: test, build, deploy on merge to main
- Secrets injected via environment/secrets manager, never committed
- HTTPS on webhook receiver; tenant-onboarding runbook with a shadow-mode period

Operational Gaps

Gaps Addendum

- Daraja OAuth token management (cached, auto-refreshed, per-tenant credentials)
- Staging environment against Daraja sandbox, isolated from production
- Dependency vulnerability scanning (Dependabot, pip-audit, npm audit) in CI
- RBAC (admin/viewer roles) with server-side enforcement and action audit logging
- CSV data export, tenant-scoped and async for large exports
- API versioning (/v1/...) with a documented deprecation policy
- Documented secrets rotation schedule and process

Tenant Lifecycle, Threat Model, Feature Flags, Billing, Help Docs

Tenant/Threat/Billing Addendum

- Tenant provisioning workflow with a shadow_mode default for new tenants
- Dedicated threat model for reconciliation-logic-specific attacks (spoofing, replay, compromised connectors)
- Per-tenant feature flags and rule versioning, tagged on every discrepancy record
- Usage tracking now; payment integration only once pricing is decided
- Plain-language Getting Started guide and FAQ for non-technical users

Data Residency, Localization & Payment Scope

Addendum III

- Document data storage locations and jurisdiction; evaluate Kenya/East-Africa hosting
- Kiswahili translation of dashboard, alert templates, and help docs with language preference per tenant/user
- Explicit, documented scope decision on M-Pesa-only vs. multi-payment-method expansion
- **Best validated directly with real pilot candidates** — see Phase 0 follow-up questions

Business & Operational Readiness

Not phases in the technical sense — these run in parallel starting no later than Phase 5, since a real pilot customer's data will touch the system well before Phase 11. None of this is legal advice; each item should go through a qualified professional before use with a real customer.

Item	Why It Matters
Terms of Service & Privacy Policy	Governs the relationship and data handling with each business customer
Data Processing Agreement (DPA)	Defines liability if reconciliation misses something or data leaks
ODPC registration	Required under Kenya's Data Protection Act above a certain scale
E&O / liability insurance	You are the system a business relies on to catch missing money
Pricing/packaging	Flat fee, per-transaction, or volume-tiered — needed before Phase 13 billing work
One-page pilot agreement	Scope, duration, and what happens after the pilot period
Support channel & SLA	Explicit expectation-setting, even informally, at pilot scale

Where to start: Phase 0 discovery conversations resolve more of the open questions across every later phase — localization, data residency, payment-method scope, and pricing — than additional planning can. The roadmap above is complete as a spec; the highest-leverage next action is running those conversations.